

TERAPIA
PRIVACIDADE E PROTEÇÃO DE DADOS

RIPD/DPIA Técnico e Engenharia de Privacidade

Dados sensíveis, adolescentes, LINDDUN, retenção e direitos

Projeto	TerapIA: Plataforma Móvel para apoio mental com Inteligência Artificial
Coordenador	Carlos Gracioli Neto
Instituição	Instituto Federal de Educação, Ciência e Tecnologia de Mato Grosso - IFMT - Campus Várzea Grande
Período	01/09/2025 a 31/08/2026
Referência	Projeto de Pesquisa 138/2025 - PROPES/IFMT

Repositório técnico e documentação: <https://github.com/devfullstackNeto/terapia>

Entrega final - 2026

1. Finalidade e escopo

Este documento consolida avaliação técnica de impacto e engenharia de privacidade. Não substitui o RIPD institucional formal. O tratamento de dados de crianças e adolescentes deve observar o melhor interesse, as bases legais aplicáveis, minimização, transparência apropriada à idade e medidas proporcionais ao risco.

2. Inventário de dados

Categoria	Necessidade	Sensibilidade	Padrão técnico
Faixa etária	UX/política	Pessoal	Faixa, evitando data completa quando desnecessária
Conta	Acesso	Pessoal	Segregação e menor privilégio
Check-in	Função principal	Sensível/contextual	Opcional e com retenção definida
Diário	Recurso privado	Muito alta	Opt-in, fora das análises e da IA por padrão
Mensagens	Apoio	Alta	Retenção mínima/configurável e registros reduzidos
Evento de segurança	Proteção	Alta	Categoria/ação; minimizar conteúdo bruto
Agendamento	Serviço	Alta	Acesso restrito
Telemetria	Qualidade	Baixo-médio	Agregada e minimizada

3. LINDDUN

Ameaça	Exemplo	Mitigação
Linkability	Correlacionar humor e agenda ao longo do tempo	Pseudonimização e análises agregadas
Identifiability	Inferir identidade em grupo pequeno	Supressão n<5 e minimização
Non-repudiation	Logs revelarem comportamento íntimo	Auditar ação administrativa, não conteúdo
Detectability	Revelar uso de recurso de saúde mental	Notificações discretas e opt-in
Disclosure	Vazamento de diário/conversa	RBAC, criptografia e segurança de backup
Unawareness	Jovem não compreender IA/coleta	Avisos simples e contextuais
Non-compliance	Uso além da finalidade	Inventário, finalidade e auditoria

4. Fluxos e fronteiras de confiança

O conteúdo enviado a provedor externo atravessa fronteira de confiança e deve ser minimizado antes do envio. O diário não cruza essa fronteira por padrão. A pesquisa utiliza dados sintéticos ou agregados autorizados e permanece separada do fluxo individual.

5. Retenção proposta

Categoria	Referência técnica	Justificativa
Conta	Enquanto ativa + período institucional	Gestão de acesso
Consentimentos	Conforme obrigação/auditoria	Versão e revogação
Check-ins	Configurável, por exemplo 6-12 meses	Histórico pessoal sem retenção indefinida
Diário	Controle do usuário	Alto risco
Conversa	Preferir 30-90 dias ou metadados	Minimização
Eventos de segurança	Período do protocolo	Segurança/auditoria
Agregados	Mais longo se anonimizados	Pesquisa e gestão

6. Direitos e UX de privacidade

- Visualizar categorias armazenadas.
- Exportar dados próprios.
- Excluir dados opcionais.
- Revogar consentimentos quando aplicável.
- Controlar notificações.
- Compreender eventual envio a provedor externo.
- Receber informação apropriada à idade.
- Contatar equipe responsável/encarregado.

7. Riscos de alto impacto

Risco	Nível	Controle mínimo
Conteúdo íntimo acessível indevidamente	Crítico	RBAC + criptografia + auditoria
Grupo pequeno reidentificado	Alto	Supressão n<5 + agregação
Transferência externa não transparente	Alto	Aviso + configuração + opção de desativar
Diário usado para treinamento/personalização sem consentimento	Crítico	Proibição arquitetural
Notificação revela uso de saúde mental	Alto	Texto discreto e opt-in